

Bezpečnost IS/IT

Základní pojmy informační bezpečnosti

Složky informačního systému (IS) z hlediska obecného:

- informační technologie - vstup, zpracování, uložení, přenos, prezentace dat
 - hardware - HW komponenty výpočetních systémů (CPU, HDD, RAM), propojovací síťové prvky, kabely, zdroje atd.
 - software - operační systémy, aplikační programové vybavení
- data - soubory a databáze, vstupní data, výstupní sestavy, výsledná data apod.
- lidé - uživatelé, obsluha, správci operačních systémů, databází, sítí

IS (jeho komponenty) představuje majetek s určitou hodnotou - *aktiva*.

Složky IS z hlediska potřeb jejich zabezpečení:

- objekty - pasivní entity, přijímají nebo obsahují informace, přístup pro autorizované subjekty
- subjekty - aktivní entity (uživatelé, procesy, výpočetní systémy, zpracovatelské aplikace, je třeba je autorizovat pro přístup k objektům, k provádění změn stavu objektů apod.

Autorizace - určení, že daný subjekt je pro určenou činnost důvěryhodný z hlediska této činnosti. Autorizace subjektu vyžaduje jeho autentizaci.

Autentizace - procedura ověření pravosti identity objektu nebo subjektu. Po úspěšné autentizaci je objekt nebo subjekt z hlediska autorizovaného subjektu **důvěryhodný**.

Zranitelné místo

vlastnost IS, umožňující útok na IS. Důsledek chyb

- v návrhu
- ve specifikaci požadavků
- v implementaci
- v provozu

Podstata zranitelného místa:

- fyzická - nevhodné umístění komponenty IS
- přírodní - neovlivnitelné přírodní jevy (záplavy, zemětřesení, požár způsobený úderem blesku atd.)
- v konstrukci HW - nespolehlivost, nestabilita
- v nedokonalosti SW - "zadní vrátka" apod.
- fyzikální - např. elmag. vyzařování umožňující odposlechy
- v lidském faktoru - nesvědomitost, nízká kvalifikace, špatný úmysl

Hrozba

možnost využití zranitelného místa IS k útoku na něj s následkem způsobení škod na aktivech.

Hrozba může být **pasivní** (objektivní) plynoucí z přírodních, fyzických nebo fyzikálních skutečností, nebo **aktivní** (subjektivní) plynoucí z lidského faktoru - úmyslná nebo neúmyslná.

Hrozby charakterizuje:

- motivace
- frekvence uplatnění
- kritičnost uplatnění

Útok

(bezpečnostní incident) využití zranitelného místa - úmyslné nebo neúmyslné.

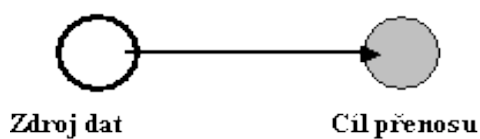
Typy útoků podle cíle:

- přerušení - proti dostupnosti, aktivní
- odposlech - proti důvěrnosti, pasivní
- záměna - proti integritě, aktivní
- zfalšování - proti integritě, autenticitě, aktivní

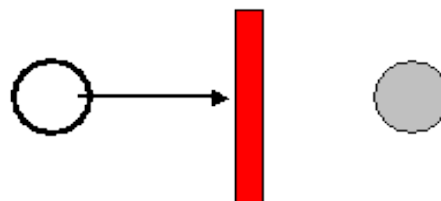
Charakteristika útoku

- podle záměru: úmyslný, neúmyslný, náhodný
- podle objemu způsobených škod: katastrofický, významný, nevýznamný (přijatelný)

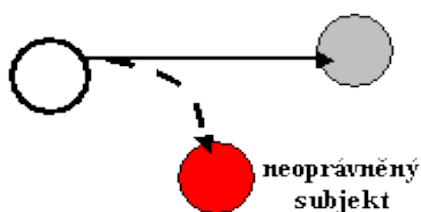
Typy útoků



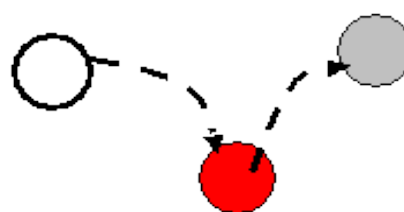
(a) Korektní přenos



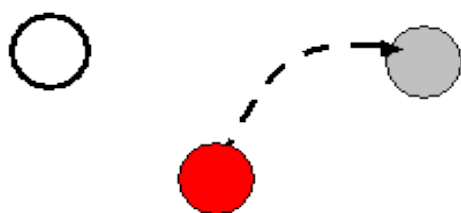
(b) Přerušení



(c) Odposlech



(d) Záměna



(e) Zfalšování dat

Riziko

pravděpodobnost využití zranitelného místa k útoku, tj. pravděpodobnost uplatnění hrozby.
Riziko charakterizuje objem potenciální škody.

Bezpečnostní cíle

směřují k zajištění pro aktiva jejich

- integritu
- důvěrnost
- dostupnost
- autenticitu
- prokazatelnost odpovědnosti
- nepopíratelnost zodpovědnosti
- spolehlivost

Bezpečnostní funkce

(bezpečnostní opatření, protiopatření) - prostředky k dosažení bezpečnostních cílů.

Typy BF podle podstaty:

- administrativní
- fyzické
- logické

Typy BF podle času uplatnění:

- preventivní
- průběžné - heuristické
- detekční
- opravné

Bezpečnostní mechanismy

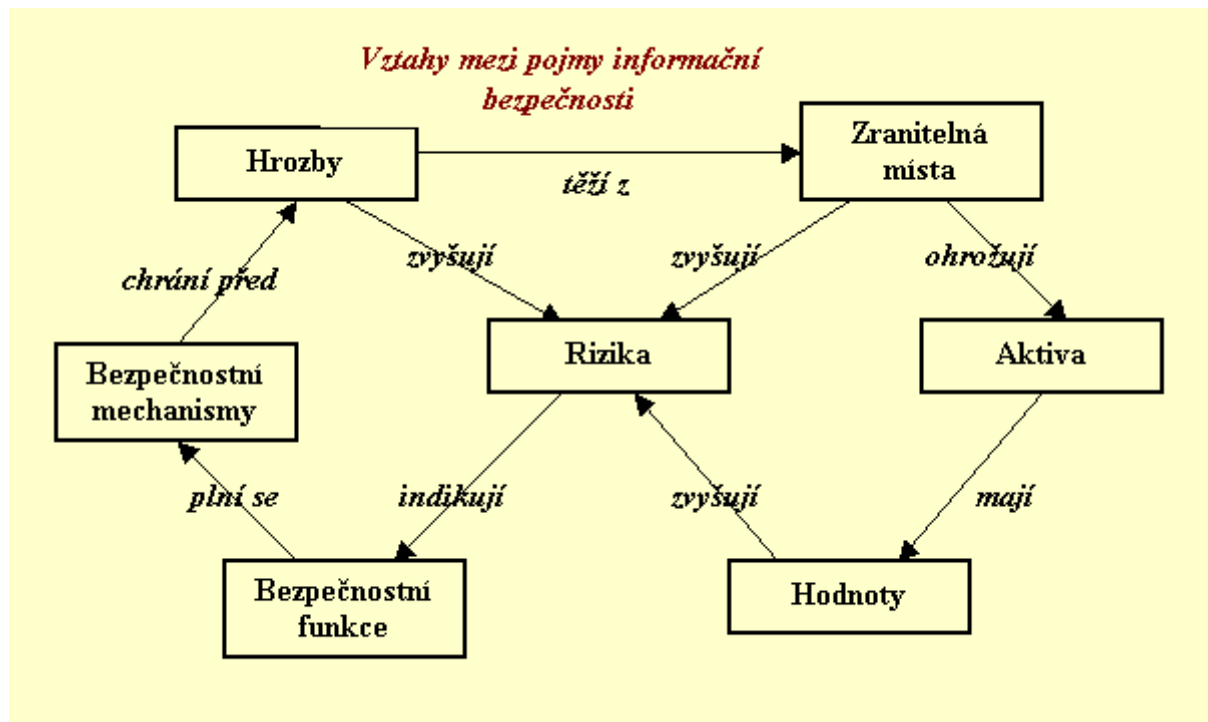
implementace bezpečnostních funkcí. Podle charakteru technologického řešení:

fyzické
hardwarové
softwarové
administrativní

Podle úrovně zabezpečení:

slabé
střední
silné

Hodnocení podle úrovně zabezpečení - evaluační standardy.



- Jeden bezpečnostní cíl může být pokryt více bezpečnostními mechanismy
- Jeden bezpečnostní mechanismus může pokrýt více bezpečnostních cílů
- Neexistuje možnost stoprocentně zabezpečit IS současnými technologiemi

Výstavba bezpečnostní politiky

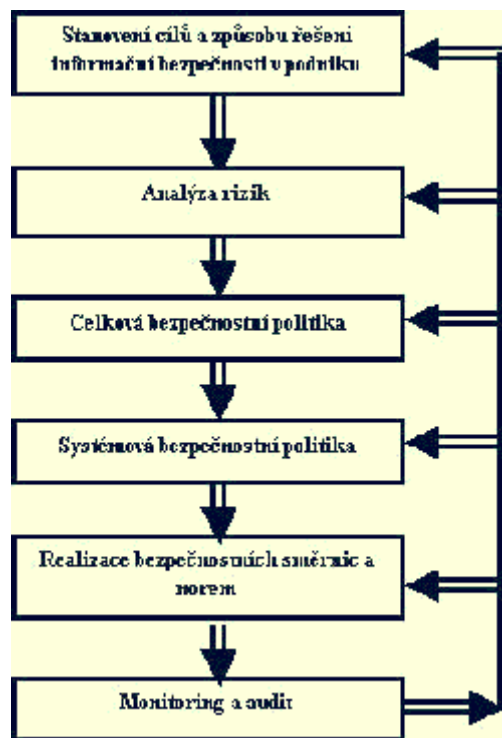
Synonyma pro termín *Bezpečnostní politiku IS* (dále BPIS):

- Informační bezpečnostní politika
- Systémová bezpečnostní politika
- Bezpečnostní politika ochrany informací

BPIS zajišťuje potřebnou úroveň důvěrnosti, autenticity a integrity dat v IS podniku a zajišťuje požadovanou bezpečnost transakcí v distribuovaném prostředí (Internet)

Požadavek na úplnost BPIS: dokument musí pokrýt všechny významné oblasti informační bezpečnosti organizace

Průběh řešení informační bezpečnosti v podniku



Řešení BPIS probíhá v procesních krocích.

0. krok - "Nultý krok" - rozhodnutí managementu zabývat se bezpečnostní politikou. To představuje:

- určení zásadních *cílů, strategií a politik* pro informační zabezpečení organizace
- určení *požadavků* na informační zabezpečení organizace
- určit pravomoci a zodpovědnosti
- identifikace a analýza *hrozeb* pro informační aktiva organizace
- identifikace a analýza *rizik* plynoucích z provozování IS
- určení přiměřených *bezpečnostních opatření (BO)* snižujících rizika na přijatelnou úroveň
- *sledování* implementaci BO a provoz IS se zavedenými BO
- zavedení programu pro *zvyšování kvalifikace* uživatelů IS v oblasti informační bezpečnosti
- *sledování a zaznamenávání* všech bezpečnostních incidentů a pokusů o ně s vyvozením patřičných důsledků

1. krok - "Analýza rizik" (AR) - klíčová aktivita celého procesu, výstupem jsou dokumenty obsahující výsledek analýzy (popis systému, zjištěná úroveň hrozeb, zjištěná zranitelná místa, zjištěná úroveň stávajících bezpečnostních opatření, návrh bezpečnostních opatření snižujících rizika na **přijatelnou úroveň**)

2. krok - dokument "Celková bezpečnostní politika" (CBP) - dlouhodobá platnost - nezávislost na současně používaných IT - definice citlivých dat - potřebné síly bezpečnostních mechanismů - stanovení hierarchie zodpovědnosti, pravomocí a práv pro subjekty a objekty IS. Dokument musí být v souladu s organizačním řádem podniku.

3. krok - "Systémová bezpečnostní politika" (SBP)- definuje způsob implementace Celkové bezpečnostní politiky v konkrétním prostředí (na konkrétních informačních technologiích) - rozpracování zásad do detailní podoby - do závazných podnikových směrnic, předpisů, norem. Musí být zcela v souladu s CBP. Častější frekvence úprav v závislosti na změnách v infrastruktuře IS. Vychází z výsledků AR, zahrnuje:

- **Fyzickou SBP** - ochrana fyzických aktiv
- **Personální SBP** - řeší ochranu před hrozbami představovanými uživateli IS a neautorizovanými lidskými subjekty
- **Komunikační SBP** - zabezpečení objektů zajišťujících komunikaci
- **Provozní SBP** - programy zvyšování kvalifikace, postupy při provádění preventivních opatření, postupy pro detekci podezřelých událostí a pokusů o útok, postupy po uskutečněných útocích ("**Havarijní plán**"), postupy při zajištění znovuzprovoznění IS ("**Plán obnovy**", "**Plán provozní kontinuity**")

Typy bezpečnostních politik:

- **Promiskuitní BP** - neomezující, zaručuje minimální nebo nulovou úroveň bezpečnosti IS
- **Liberální BP** - neopatrná, explicitní zákazy, vhodné řešení pro IS se slabými hrozbami a nízkým ohodnocením informací
- **Racionální BP** - opatrná, explicitní povolení, zaručuje vyšší stupeň bezpečnosti, vyžaduje provedení klasifikace objektů a subjektů podle jejich citlivosti a povinné řízení přístupu k nim
- **Paranoidní BP** - vše zakazující, zaručuje vysoký stupeň bezpečnosti za cenu izolace IS s minimem možných přístupů

"Havarijní plán" - plán činnosti po útoku (včetně určení skladů náhradních dílů, archivů záloh atd.), průběh reakce na incident pro konkrétní osoby tvořící havarijní tým, stanovení adresné zodpovědnosti za postupy

"Plán obnovy", "Plán kontinuity provozu" (zahrnuje definici "havárie", "podezření na průnik do IS") - stanoví postupy pro definované situace - určuje priority z hlediska poslání organizace (tzv. "kritické zdroje") - směrnice pro vytváření záloh a archivů dat - směrnice pro skartace nepotřebných zdrojů informací (hrozba "ztráta důvěrnosti").

Zálohování kritických zdrojů:

- *Hot site* (kompletní kopie produkčního prostředí včetně HW)
- *Warm site* (průběžné zálohy, méně výkonný hw, obnova v řádech dnů)
- *Cold site* (bez záložního hw)
- a alternativy

4. krok - implementace informační bezpečnosti, přijetí a uvedení do života SBP - postupné řešení dílčích kroků a projektů (např. systém monitorování, zajištění bezpečnostního vzdělávání...)

Problémy a chyby:

- mnoho kompromisů
- nereálná politika - v současném stavu věcí nevyhovuje - potřeba postupného řešení
- neadekvátní rozsah politiky - negativní dopad na výkonnost IS
- nedostatečná propagace BP
- přebírání nevhodných vzorů

5. krok - monitoring a audit - průběžné sledování provozu IS a vyhodnocování stupně jeho zabezpečení, vytvářejí zpětnou vazbu se všemi předchozími fázemi výstavby informační bezpečnosti a implikují změny v bezpečnostním systému. Vzniká cyklus řízení informační bezpečnosti, uplatňují se zde podsystémy:

zajištění prevence proti bezpečnostním incidentům (např. systémy pro řízení přístupů, nástroje pro ověřování autenticity subjektů a objektů, integrity dat aj.)

zajištění detekce pokusů o průnik do IS, tzv. IDS - Intrusion Detection System (zpravidla SW řešení automaticky vyhodnocující systémové žurnály)

zajištění obnovy po bezpečnostním incidentu, tzv. Recovery Technologies

Možnost spolupráce s externími firmami, delegace řešení informační bezpečnosti (outsourcing informační bezpečnost) - potenciální riziko zranitelnosti - nutné ověřit:

důvěryhodné reference

profesní certifikáty řešitelského týmu

používané metodiky pro řešení projektu a řízení projektu

smluvně zajištěná ochrana informací

ekonomická stabilita řešitelské firmy

Řešení řízené informační bezpečnosti je projekt náročný časově i finančně. Informační bezpečnost je nutné řešit také v organizacích, které provozují informační systému menšího rozsahu a které se dosud bezpečností informací důsledně nezabývaly. Průzkumy (*University of Texas, U.S. Small Business Administration*) prokazují, že přístup k informacím je kritická oblast komerce. Z podniků, u nichž došlo k totální ztrátě podnikových dat v důsledku havárie informačního systému, zaniklo téměř 50% takto postižených podniků. Na svou původní úroveň se nedostalo ani po dvou letech působení téměř 90% podniků. Dále tyto průzkumy zjistily, že ani u většiny nových podniků není informační bezpečnosti věnována dostatečná pozornost, přestože ztráta dat významně ohrožuje podnikání.

U informačních systémů menšího rozsahu je možno volit postup, kdy na základě praktických zkušeností a doporučení odborníků na informační bezpečnost je proveden soupis rizik, jejich vyhodnocení a následná opatření na jejich vyloučení nebo pokrytí. Takové řešení může dočasně překlenout závažné bezpečnostní trhliny v IS podniku. Současně musí ovšem probíhat řešení projektu informační bezpečnosti podle normalizovaného postupu.

Příklad doporučeného postupu odborníky U.S.Data Trust Corporation

Oblasti pokryté systémovou BP

- fyzická bezpečnost (např. umístění počítačů, kabeláže, zajištění přístupu do objektů...) autentizace a síťová bezpečnost (bezpečnost uživatelských připojení, vzdálené přístupy, intranet, extranet, autorizace služeb...)
- elektronická pošta (administrace mail serverů, práva používání e-mail, monitorování, archivace, omezení velikosti zpráv, digitální podpisy, zajištění důvěrnosti šifrou...)
- Internet a internetové služby (propojení k Internetu, firewally, NAT, odpovědnost správců, uživatelů, autentizace internetových transakcí, přístup do Web systému, zodpovědnost za obsah Web dokumentů, bezpečnost CGI, přenos dat FTP, e-commerce...)
- viry, červi, trójské koně (pravidla pro používání SW „třetích stran“, používání antivirových programů, testování integrity systémů...) šifrování (generování a správa šifrovacích klíčů, PKI...)
- personální politika organizace (přijímání, odchody, změny pracovních zařazení...) vývoj SW (osobní zodpovědnosti a pravomoci, testování, dokumentace, účast „třetích stran“...)
- konfigurace systémů, správa výkonných práv v systémech provoz (zvyšování kvalifikace uživatelů, bezpečnostní školení, postupy při haváriích - havarijní plány, při detekci útoku...)

Norma stanovující metodiku pro výstavbu bezpečnosti IS

ČSN ISO/IEC TR 13335-1	Informační technologie - Směrnice pro řízení bezpečnosti IT - Část 1: Pojetí a modely bezpečnosti IT
ČSN ISO/IEC TR 13335-2	Informační technologie - Směrnice pro řízení bezpečnosti IT - Část 2: Řízení a plánování bezpečnosti IT
ČSN ISO/IEC TR 13335-3	Informační technologie - Směrnice pro řízení bezpečnosti IT - Část 3: Techniky pro řízení bezpečnosti IT
ČSN ISO/IEC TR 13335-4	Informační technologie - Směrnice pro řízení bezpečnosti IT - Část 4: Výběr bezpečnostních opatření

- **ISO/IEC TR 13335-1** popisuje základní koncepce a modely používané pro správu bezpečnosti IT a její vztah ke zprávě informačních technologií. Definovány jsou zde rovněž základní pojmy bezpečnosti IT, které doporučujeme jednoznačně organizace převzít. Otázka správných a přesných definic je v dokumentu důležitá. Tato první část je především určena pro členy bezpečnostní rady a pracovníky, kteří zodpovídají za bezpečnost IT a pro ty, kteří mají na starost celkový program bezpečnosti organizace..
- **ISO/IEC TR 13335-2** popisuje řídicí a plánovací aspekty IT. Je jí možné aplikovat na organizaci a řízení bezpečnosti IT v organizace, definuje role a zodpovědnost jednotlivých zainteresovaných pracovníků. Je z ní možné čerpat pro definici cílů a prvků celkové bezpečnostní politiky IT v organizace a bezpečnostní politiky jednotlivých systémů IT. Jsou zde vysvětleny významy různých analýz a přístupů k nim. Dále je zde popsán výběr bezpečnostních opatření a přijetí zbytkového rizika. V neposlední řadě je zde uvedeno plánování bezpečnosti, zavádění bezpečnostních opatření, výchovného programu a následné údržby, monitorování, kontroly plnění a řešení incidentů. Tato druhá část je určena pro vedoucí pracovníky z oblasti systémů

IT organizace a ty, kteří zodpovídají za aktivity organizace, na kterých se IT podílí rozhodující měrou.

- **ISO/IEC TR 13335-3** popisuje nejdůležitější bezpečnostní techniky, uvádí jejich strukturu a kategorizaci. Podrobně jsou zde rozebrány způsoby provádění rizikové analýzy a volba a strategie této analýzy. Tato část je určena pracovníkům organizace, kteří se podílejí na životním cyklu projektů plánování, návrhů, implementace, testování, pořízování a provozu systémů IT z hlediska jejich bezpečnosti.
- **ISO/IEC TR 13335-4** předkládá doporučení na výběr bezpečnostních protiopatření v kontextu specifických potřeb organizace.

Pracovníci v řízení informační bezpečnosti

- **vedoucí zaměstnanci** – nesou odpovědnost za realizaci bezpečnostních opatření správci IS - odpovídají za správnost informací, funkčnost systémů a řízení přístupu k informacím
- **provozovatelé (administrátoři) IS** – zajišťují činnost systému v souladu s dokumentací
- **uživatelé informací (pracovníci s řízeným přístupem k IS)** – používají IS ke své činnosti v rámci organizace
- **externí smluvní zaměstnanci a dodavatelé** (outsourcing, systémová podpora, vývoj aplikací) – smluvně stanovený přístup k IS

Analýza rizik

motto: *Rizika existují, je třeba je mít pod kontrolou*

- Analýza rizik (AR) - klíčová aktivita v procesu řešení bezpečnosti.
- Cíl AR - popis potenciálních rizik a příspěví k jejich snížení na přijatelnou úroveň
- Bez kvalitní AR nelze vytvořit systém řízení informační bezpečnosti
- AR odpovídá na otázky:
 1. Co nastane, když nebudou informace chráněny?
 2. Jak může být bezpečnost informací porušena?
 3. Jaká je pravděpodobnost, že to nastane?
- Věcným výstupem procesu AR je dokument/sada dokumentů obsahujících:
 - popis IS
 - stanovení úrovně hrozeb
 - odhad ztrát
 - stanovení protiopatření
 - určení zbytkových rizik
- AR - podklad pro další kroky při tvorbě systému řízení informační bezpečnosti
- Na základě AR vznikají další dokumenty:
 - Havarijný plán
 - Plán obnovy provozu IS
 - Plán zvyšování bezpečnostní kvalifikace zaměstnanců
 - atd.

Postup při vytváření AR (obecný model):

1. stanovení oblasti IS, kde bude analýza prováděna
2. identifikace a ocenění aktiv
3. určení zranitelných míst
4. odhad pravděpodobnosti využití zranitelných míst (odhad rizik)
5. výpočet očekávaných ročních ztrát (hodnota ALE /Annual Loss Expectancy/ nebo EAC /Estimated Annual Cost/)
6. návrh použitelných bezpečnostních funkcí a bezpečnostních mechanismů pro jejich implementaci včetně nákladů na jejich pořízení.
7. odhad ročních úspor po jejich zavedení.

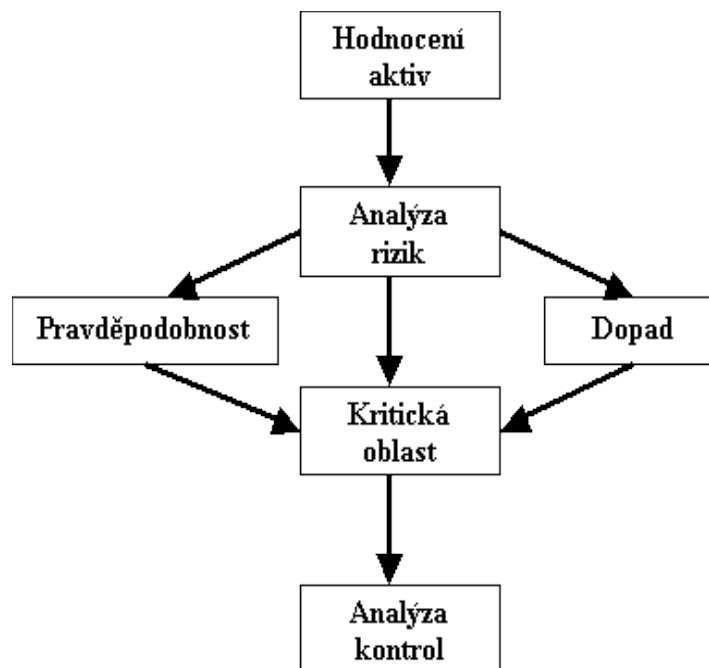
Definice způsobů provádění AR (podle standardu ISO/IEC TR 13335 - norma metodiky pro výstavbu informační bezpečnosti):

- **Orientační analýza** - úvodní, následuje rozhodování o strategii pro vlastní analýzu rizik informačního systému
- **Elementární** (přehledová) - pro rychlé zavedení bezpečnostních opatření (BO), rychlé řešení, poměrně nízké finanční náklady. Bezpečnostní opatření jsou stanovena na základě analogie s jinými systémy nebo podle určitého standardu.
Nevýhoda: navrhovaná BO nemusejí přesně odpovídat daným rizikům, nelze odhadnout dopad změn konfigurace IS na bezpečnost
Vhodné řešení pro organizace s menší závislostí na IS a nižší požadovanou úrovní informační bezpečnosti
- **Neformální** (pragmatická) - provádí se na základě znalostí a zkušeností bezpečnostních expertů, nepoužívá formální metody.

Je vypracováno několik postupů, např.:

1. Definice rizik a oblastí hrozeb
 2. Pro každé riziko se provede odhad jeho dopadu a pravděpodobnost výskytu. Vyhodnotí se stupni: nepřijatelné (musí být odstraněno), poškozující (mělo by být odstraněno - zvážit náklady), přijatelné (musí být sledováno), zanedbatelné (není třeba dále analyzovat).
 3. Identifikace ochranných opatření pro odstranění ev. zmírnění určených rizik
 4. Posouzení zbytkového rizika
- **Detailní** - prováděná formálními standardními metodami (podle ISO/IEC 17799 - BS7799 (Velká Británie) - IT-Grunschutzhandbuch (SRN)). Podpora speciálního SW - CRAMM, Cobra. Katalog hrozeb - ISO/IEC TR 13335.
Nejpřesnější, časově i finančně nejnáročnější.

Schéma postupu podle standardu BS7799:2:



1. *Identifikace a ohodnocení aktiv*

- vymezení části IS, kde bude AR provedená
- identifikace všech aktiv
- ohodnocení všech aktiv peněžními i nepeněžními měřítky (poškození legislativy, zhoršení výkonu organizace, ztráta prestiže, ztráta důvěry, ohrožení osobní bezpečnosti, porušení obchodního tajemství, narušení veřejného pořádku, zhoršení bezpečného prostředí...)

sběr údajů formuláři, dotazníky....

2. *Posouzení hrozeb* - podle původu, úmyslu.

- identifikace hrozeb podle katalogu hrozeb ISO/IEC TR13335.
- odhad pravděpodobnosti výskytu hrozby - podle typu hrozby (interní, externí - přírodní, fyzické....)

Výstup:

- Seznam hrozeb
- Pravděpodobnost výskytu (vysoká, střední, nízká)

3. *Odhad zranitelnosti*

- analýza zranitelnosti - určení zranitelných míst
- popis možnosti využití zranitelných míst - rizikové/havarijní scénáře

Výstup:

Seznam zranitelných míst s určením stupně zranitelnosti (vysoký/střední/nízký)

4. *Výběr ochranných opatření* - podle typu preventivní (plán preventivní ochrany), následná (havarijní plán, plán obnovy).

Výsledek:

Seznam stávajících a plánovaných ochranných opatření. Stav jejich implementace a využívání.

5. **Přijetí rizik** - identifikace zbytkových rizik po implementaci navržených opatření.

Tabulka:

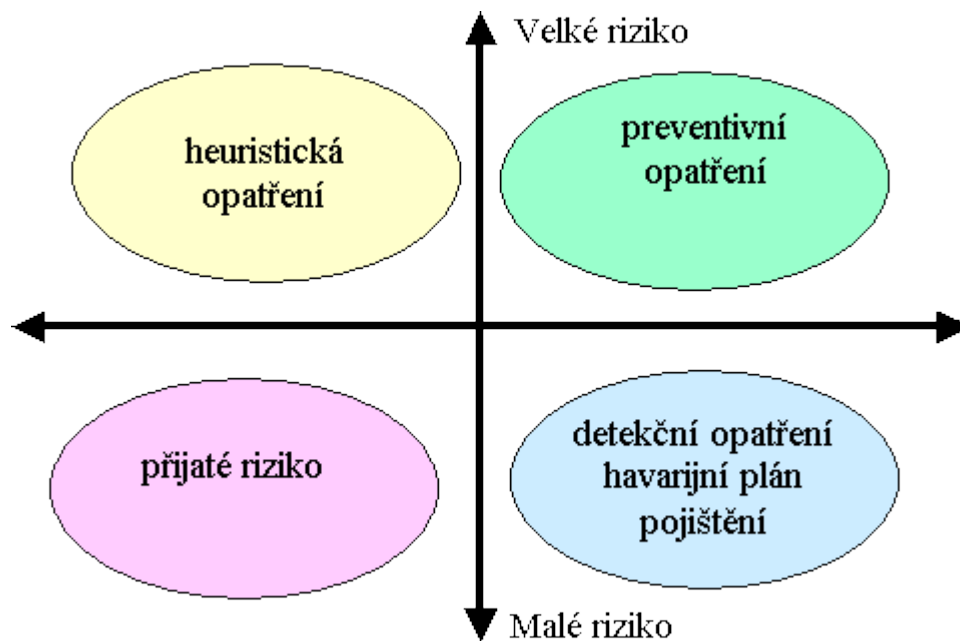
hrozba - velmi nízká/nízká/střední/vysoká/velmi vysoká

zranitelnost - nízká/střední/vysoká

Výsledek:

riziko - nepřijatelné/poškozující/přijatelné/zbytkové

Výše rizika určuje priority pro implementaci nutných nových bezpečnostních opatření



Obr. 1 - Schéma výběru ochranných opatření

Formální metody - dva typy:

- o Kvantitativní AR:

výpočet *pravděpodobnost výskytu události X potenciální ztráta = odhad ztrát (očekávaná ztráta) - ALE/EAC*

Problém: nespolehlivost výsledku daná nepřesností výchozích údajů

Výhoda: jednoduché řešení

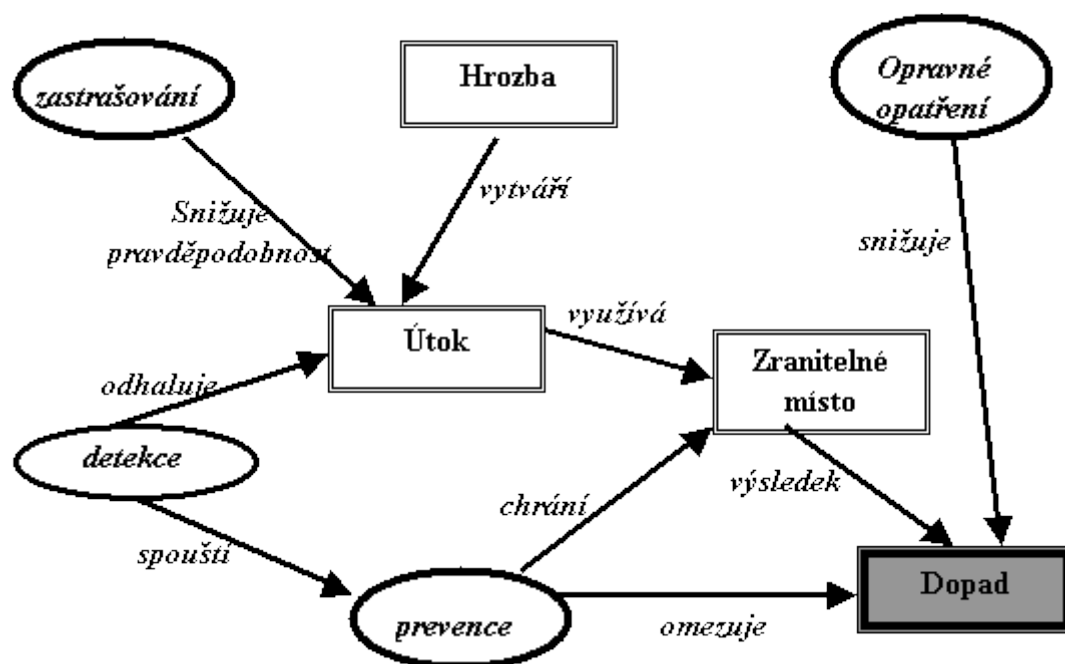
- o Kvalitativní AR:

v současnosti preferovaná, SW nástroje na podporu stanovení AR: COBRA, RiskWatch, CRAMM

Princip: vytvoření relačního modelu - vzájemně svázané komponenty: hrozby, zranitelná místa, protiopatření.

Protiopatření:

- zastrášovací nástroje
- preventivní opatření
- detektivní opatření
- opravná opatření



Obr. 2 - Schéma vztahů složek informační bezpečnosti

Standard BS 7799

BS7799 - nejznámější bezpečnostní standard s celosvětovým rozšířením

Původně publikován v r. 1995, několikrát revidován

Přijat jako mezinárodní standard ISO17799 v prosinci 2000

Úplné pokrytí všech bezpečnostních oblastí

Popisuje velký počet bezpečnostních opatření

Podpora pro výstavbu efektivní bezpečnostní politiky pro různé typy organizací

Další informační zdroje:

<http://www.thewindow.to/bs7799> - The BS7799 Security Zone

<http://www.xisec.co.uk> - Security Management Systems and the official web site of the ISMS International User Group (IUG)

Struktura BS 7799:

- BS7799-1:1999 (ISO/IEC 17799:2000) - Code of Practice for Information Security Management (Katalog bezpečnostních funkcí a bezpečnostních opatření)
 - o shrnutí praktických zkušeností s řešením informační bezpečnosti
 - o standard definuje 127 bezpečnostních funkcí rozložených do 10 sekcí - bezpečnostních zón:
 1. Bezpečnostní politika - pojednává o řízení a podpoře řešení informační bezpečnosti ze strany managementu
 2. Organizace informační bezpečnosti - se zabývá organizačním zajištěním bezpečnosti, správou bezpečnosti v případech, kdy mají přístup ke zpracování informací tzv. "třetí strany", v případech outsourcingu apod.

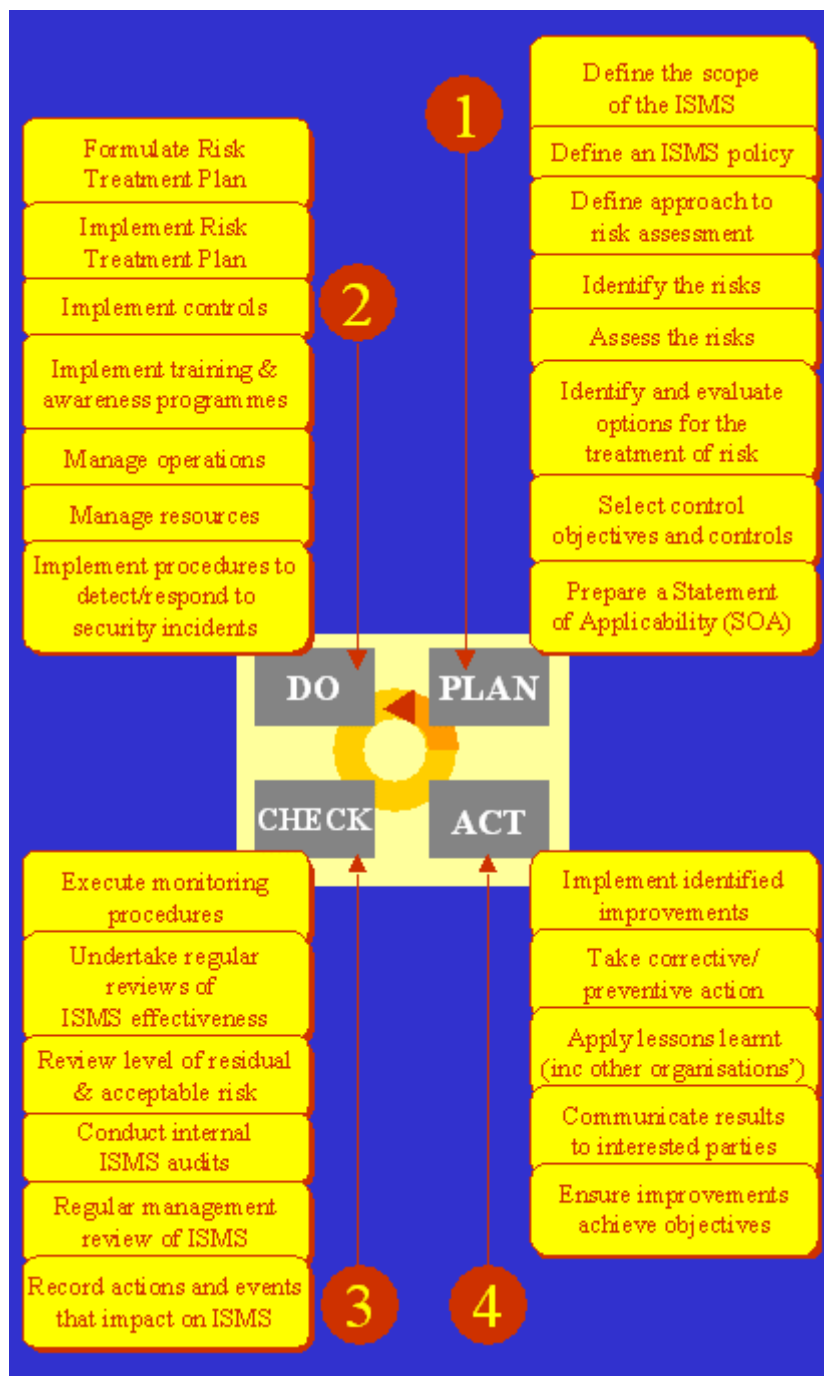
3. Klasifikace a správa aktiv - pojednává a přidělení hodnoty určitým informacím podle síly dopadu na podnik při jejich ztrátě nebo nedostupnosti a o zajištění určitého stupně ochrany
4. Personální bezpečnost - cílem je omezení rizik od chyb lidí, tj. zcizení nebo zneužití informace. Zajištění administrativního a správního řešení - obsah pracovních smluv, směrnice, školení, atd. Vytvořit povědomí a významu informační bezpečnosti, dosažení podpory bezpečnostních politiky při běžných pracovních aktivitách
5. Fyzická bezpečnost a bezpečnost prostředí - fyzická ochrana zařízení, kde probíhá zpracování informace, minimalizace bezpečnostní hrozby prostředí
6. Správa počítačů a sítí - cílem je:
 - zajistit korektní a bezpečnou funkci všech procesů zpracovávajících informace
 - minimalizovat rizika selhání systémů
 - ochrana integrity dat a SW
 - správa integrity a dostupnosti zpracování informace a komunikace
 - zajištění bezpečnosti pro data, procházející sítí a ochrana infrastruktury
 - prevence proti poškození dat a přerušení činnosti podniku
 - prevence proti ztrátě dat, modifikaci a zneužití při mezipodnikových procesech
7. Systémy řízeného přístupu - zajištění řízeného přístupu k informacím, prevence proti neautorizovaným přístupům k IS, ochrana síťových služeb, prevence proti neautorizovaným přístupům k počítačům, detekce neautorizovaných aktivit, zajištění bezpečnosti při použití mobilních zařízení k přístupu do sítě
8. Vývoj a údržba systému - vývoj nových systémů v bezpečném prostředí, požadavky na bezpečnost nových systémů jsou jednoznačně stanoveny, ochrana důvěrnosti, autenticity a integrity dat při vývoji nových systémů, údržba bezpečnosti aplikací a dat
9. Havarijní plány a plán obnovy - protiopatření proti přerušení činnosti podniku a kritických podnikových procesů v důsledku zásadních selhání IS nebo katastrof (BCP - Business Continuity Plan)
10. Soulad - soulad s existující legislativou a jinými bezpečnostními normami a předpisy podniku, zajištění omezení možnosti zásahů do auditních procesů



Obr. 1 - Struktura BS7799-1:1999

- *BS7799-2:1999 - Specification for Information Security Management Systems (ISMS)*
 - o návod k výstavbě ISMS, šest kroků, jejichž výsledkem je sada dokumentů definujících ISMS:
 1. Identifikace informačních aktiv
 2. Definice rozsahu systému řízení informační bezpečnosti
 3. Analýza rizik
 4. Definice metod ("safeguards") řízení rizik
 5. Identifikace všech bezpečnostních kontrol (bezpečnostních protiopatření)
 6. Vytvoření kontrolního mechanismu pro správu bezpečnostního systému
- *BS7799-2:2002 - Specification for Information Security Management Systems (ISMS)*
 - o inovace standardu BS7799-2:1999
 - o dává instrukce **jak** aplikovat standard ISO/IEC 17799:2000 a **jak** provozovat, udržovat a vylepšovat ISMS. Předchozí verze BS7799-2:1999 se zabývala pouze aplikací ISO/IEC 17799:2000 a výstavbou ISMS.
 - o standard je založen na cyklu

Plan – Do – Check - Act

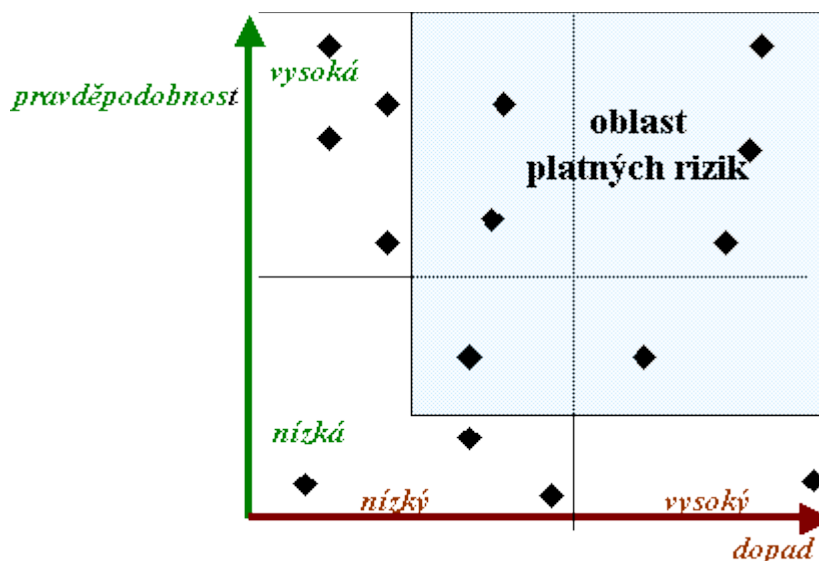


Obr. 1 - Struktura standardu BS7799-2:2002

4. Plan

- definice rozsahu ISMS (Information Security Management Systems)
- definice politiky ISMS
- definice přístupu k posuzování rizik
- identifikace rizik
- posouzení rizik
 - výběr metody AR vhodné pro typ organizace a rozsah ISMS
 - označení rizik podle dopadu na organizaci a pravděpodobnost výskytu

- určení „oblasti platných rizik“, která zahrnuje rizika vyžadující ošetření pro jejich eliminaci nebo vyloučení mimo tuto oblast



Obr. 2 - Vytyčení oblasti platných rizik

- identifikace a hodnocení podmínek pro ošetření rizik výběr bezpečnost opatření a jejich cílů příprava dokumentu SOA (Statement of Applicability)
 - identifikace všech zvolených opatření
 - odůvodnění výběru (pozitivní i negativní) vzhledem k posouzení rizik

5. Do

- formulace plánu k ošetření rizik
- implementace plánu k ošetření rizik
- implementace bezpečnostních opatření
- implementace personálních opatření (školení, budování povědomí uživatelů apod.)
- řízení činností
- řízení zdrojů
- implementace procedur pro detekci incidentů a reakce na incidenty

6. Check

- provádění monitoringu
- pravidelné revize efektivit ISMS
- revize úrovně přijatelných a zbytkových rizik
- provádění interních ISMS auditů
- správa revizí efektivit a úrovně rizik
- provádění záznamů o dějích a událostech s dopadem na ISMS

7. Act

- implementace identifikovaných vylepšení
- provádění opravných nebo preventivních akcí
- využívání zprostředkovaných zkušeností
- komunikace se zúčastněnými stranami nad výsledky
- zaručit, že implementovanými vylepšeními bylo dosaženo požadovaného cíle

Certifikace IS podle standardu BS 77899 - C:CURE - WWW site <http://www.c-cure.org>



- podpora vlády UK - snaha o přijetí standardu v mezinárodním rozsahu
- důvody k certifikaci:
 - o ochrana citlivých údajů občanů (IS v oblasti péče o zdraví),
 - o posílení důvěryhodnosti firem směrem ke klientům a partnerům,
 - o zákonná povinnost

Certifikace IS v ČR

Atestace IS na bezpečnost informace v ČR pro IS veřejné správy

- Zákon č. 148/1998 Sb., o ochraně utajovaných skutečností a o změně některých zákonů ukládá v § 51 povinnost certifikace informačního systému používaného k nakládání s utajovanými skutečnostmi
- Certifikaci informačních systémů nakládajících s utajovanými skutečnostmi zajišťuje a provádí odbor informačních technologií NBÚ na základě podané žádosti a podkladů pro provedení certifikace
- " *Atestace informačních systémů, produktů nebo připojení k referenčnímu rozhraní (dále jen 'atestace') je, podle vymezení pojmu v zákoně 365/2000 Sb., o informačních systémech veřejné správy, stanovení jejich způsobilosti pro použití v informačních systémech veřejné správy na základě shody se stanovenými standardy, technickými normami, požadovaným stupněm bezpečnosti nebo na základě dosažení vyšší úrovně technických a užitných vlastností, než požadují standardy a technické normy. Je to posouzení, zda informační systém, nebo obecně produkt, splňuje předem, většinou standardem ISVS, stanovené technické a jiné podmínky. Metodiky atestací u povinných typů atestací se stanovují standardem ISVS. Atestace jakosti produktu jsou vymezeny interní metodikou atestačního střediska, zaregistrovanou Ministerstvem informatiky. Atestace provádějí nezávislé instituce, atestační střediska, pověřené tímto ministerstvem.*"
- Obsah žádosti o certifikaci
 - stručný popis účelu a rozsahu informačního systému (účel, rozsah, stanovení běžných a minimálních funkcí)
 - stupeň utajení utajovaných informací, se kterými bude systém nakládat **(vyhrazené, důvěrné, tajné, přísně tajné)**
 - stanovení bezpečnostního provozního módu informačního systému **(vyhrazený, s nejvyšší úrovní, víceúrovňový)**
 - identifikaci dodavatele informačního systému
- Podklady pro provedení certifikace

- a. výsledky analýzy rizik
 - b. bezpečnostní politika informačního systému
 - c. návrh bezpečnosti informačního systému
 - d. sada testů bezpečnosti informačního systému, jejich popis a popis výsledků testování
 - e. bezpečnostní provozní dokumentace informačního systému
 - f. popis bezpečnosti vývojového prostředí
- Atestační střediska

Firma (společnost)	WWW site
ADA, s. r. o.	http://www.isystemy.cz
Atestační středisko, a. s.	http://www.atestacnistredisko.cz
BDO IT, a. s.	http://www.bdocert.cz
CERTPOINT, s. r. o.	http://www.certpoint.cz
EQUICA, a. s.	http://www.equica.cz
Hewlett-Packard, s. r. o	http://www.hp.cz
PVT, a. s.	http://www.pvt.cz
Relsie, spol. s r. o.	http://www.relsie.cz
secunet, organizační složka	http://www.secunet.cz

Další dokumenty pro podporu přípravy k certifikačnímu procesu

- Information Security Management: An Introduction (PD3000)
- Preparing for BS7799 Certification (PD3001)
- Guide to BS7799 Risk Assessment and Risk Management (PD3002)
- Are you ready for a BS7799 Audit? (PD3003)
- Guide to BS7799 Auditing (PD3004)
- Selecting BS7799 Controls (PD3005)